

Governing Autonomous AI Agents

Where the Frameworks Fall Short

Version	1.0
Date	2026-05-06
Author	Jay Wingard
Subject System	Genesis Autonomous AI Agent
Classification	Public

Document History

Version / Date	Author	Description
1.0 (2026-05-06)	Jay Wingard	Initial release

Contents

1	Governing Autonomous AI Agents: Where the Frameworks Fall Short	2
1.1	1. The Problem	2
1.2	2. What Makes Agents Different	2
1.2.1	2.1 External Action Authority	2
1.2.2	2.2 Persistent State and Behavioral Drift	3
1.2.3	2.3 Proactive Operation	3
1.2.4	2.4 Heterogeneous Output	3
1.3	3. Framework-by-Framework Analysis	3
1.3.1	3.1 NIST AI RMF 1.0	3
1.3.2	3.2 ISO/IEC 42001:2023	4
1.3.3	3.3 EU AI Act (Regulation 2024/1689)	4
1.4	4. Cross-Cutting Gaps	5
1.4.1	4.1 Authority Governance	5
1.4.2	4.2 Behavioral Continuity Assurance	5
1.4.3	4.3 External Impact Accountability for Delegated Action	6
1.5	5. Toward an Agentic AI Governance Framework	6
1.5.1	5.1 Authority Model Specification	6
1.5.2	5.2 Continuous Behavioral Assurance	6
1.5.3	5.3 External Action Transparency	7
1.5.4	5.4 Proactive Operation Governance	7
1.6	6. Positioning Against Adjacent Work	7
1.7	References	8
1.8	8. Limitations of This Analysis	8

Governing Autonomous AI Agents: Where the Frameworks Fall Short

Version: 1.0 | Date: 2026-05-06 | Classification: Public

1. The Problem

The three major AI governance frameworks—NIST AI RMF 1.0, ISO/IEC 42001:2023, and the EU AI Act (Regulation 2024/1689)—were designed primarily for classification systems, recommendation engines, and bounded conversational AI. They assume AI systems that receive inputs, produce outputs, and operate within a defined interaction scope. A human reviews the output. The output informs a decision. The decision produces an effect in the world.

Autonomous AI agents break this model. An agent does not just produce outputs for human review. It takes actions: sending messages, executing code, browsing the web, creating accounts, modifying files, interacting with services. The gap between “the AI produced a recommendation” and “the AI did the thing” is where existing governance frameworks lose their footing.

This document identifies where NIST AI RMF, ISO 42001, and the EU AI Act apply directly to autonomous agents, where they require adaptation, and where genuine structural gaps exist. The analysis is grounded in the practical experience of applying all three frameworks to a specific deployed autonomous agent (Genesis), documented in the accompanying assessments (D1, D2, D3).

2. What Makes Agents Different

Four characteristics distinguish autonomous AI agents from the systems these frameworks were designed to govern. Each creates specific governance challenges.

2.1 External Action Authority

Traditional AI systems produce outputs that a human interprets and acts upon. The human is the control point between the AI’s recommendation and the real-world effect. Autonomous agents collapse this gap. The agent takes the action directly—sending the email, pushing the code, posting the message, filling the form.

Governance implication: Every framework assumes a human-in-the-loop at the point of external effect. When the agent is the actor, the governance question shifts from “how do we help the human make a good decision with AI input” to “how do we constrain the agent’s authority to act.” This is a different kind of control problem.

2.2 Persistent State and Behavioral Drift

Traditional AI systems are stateless or near-stateless. A classifier produces the same output for the same input (within stochastic bounds). An agent accumulates state: memories, learned preferences, behavioral corrections, trust scores. This state shapes future behavior. Over weeks and months, an agent's behavior can drift from its initial configuration in ways that are difficult to predict or detect.

Governance implication: Frameworks assume you can validate an AI system at a point in time and that validation remains valid. For agents, the system you validated last month may behave differently today because its accumulated state has changed its effective behavior. Continuous behavioral monitoring is not optional—it is a prerequisite for meaningful governance.

2.3 Proactive Operation

Traditional AI systems respond to inputs. An agent can initiate action without a human prompt. It can decide on its own that something needs to be done, compose a plan, and begin executing—all while the human operator is asleep, offline, or not paying attention.

This breaks a core assumption in every oversight framework: Human oversight frameworks assume the human is present and attentive during system operation. An agent that operates proactively requires oversight mechanisms that function during periods without human attention. The question is not just “can the human override the AI” but “what happens when the human isn’t there to override.”

2.4 Heterogeneous Output

Traditional AI systems produce typed outputs—predictions, classifications, scores, generated text—that can be evaluated against ground truth or quality metrics. An agent produces a mix of actions, communications, knowledge artifacts, code changes, and internal state updates. There is no single metric that captures “agent output quality.”

The measurement problem is fundamental. Measurement frameworks (NIST MEASURE function, ISO 42001 A.6.2.4 verification and validation) assume measurable outputs with defined quality criteria. Agents produce outputs that are difficult to measure individually and whose quality depends on context, timing, and downstream effects that may not be observable at the time of action.

3. Framework-by-Framework Analysis

3.1 NIST AI RMF 1.0

Where it applies directly:

GOVERN and MAP-1.x (context-setting) transfer without modification—organizational risk culture, accountability structures, and stakeholder analysis are agent-agnostic.

GOV-6 (third-party risk) is particularly relevant for agents dependent on external LLM providers. See D1 Sections 2-3 for the full subcategory mapping.

Where it requires adaptation:

MAP-3.5 (human oversight) assumes human review before outputs affect the world; agents use pre-authorized action models where classification accuracy, not human review, is the safety mechanism. MEASURE-2.x needs reframing around behavioral consistency and action classification accuracy rather than prediction accuracy. MEASURE-2.11 (fairness) assumes population-level decisions—single-user agents present different bias risks around information prioritization and attention narrowing. See D1 Section 4.

Where structural gaps exist:

No subcategory addresses self-modifying behavior or proactive action initiation—both are central to agent operation. The AI RMF mentions “autonomous agents” exactly once in the 600-1 GenAI companion profile, and only as a security threat vector, not as a system type requiring governance. See D1 Section 5.

3.2 ISO/IEC 42001:2023

What transfers well:

A.6 (AI System Life Cycle) and A.9 (Use of AI Systems) transfer well—lifecycle controls, event logging, responsible use constraints, and human oversight apply regardless of system type. A.6.2.8 (event logging) is particularly strong for agents needing audit trails. See D2 Sections 3-4 for the control-by-control mapping.

Where it requires adaptation:

A.7 (Data for AI Systems) assumes curated training datasets; agents accumulate operational data (memories, corrections) that shapes behavior without formal training, requiring a different data governance model. A.4.6 (Human Resources) and A.5 (Impact Assessment) assume institutional staffing and pre-deployment assessment of static systems—both break down for single-operator agents that evolve through accumulated state. See D2 Sections 5-6.

Where structural gaps exist:

No control addresses action authority governance—what an AI system should be permitted to do autonomously versus what requires human approval. A.10 (Third-Party Relationships) assumes suppliers that can be contractually bound, which does not account for the power asymmetry between a single operator and a cloud AI provider. No control addresses behavioral drift detection in systems that change through learning rather than deliberate modification. See D2 Section 7.

3.3 EU AI Act (Regulation 2024/1689)

Where it applies directly:

Article 50 transparency obligations apply directly—if an agent sends messages, recipients should know they are interacting with AI. GPAI obligations (Chapter V) apply to model providers, creating indirect governance benefits for agent operators. See D3 Section 3.

Where it requires adaptation:

Article 6 and Annex III classify by use case, not by capability or authority level—an agent with broad action authority is classified the same as a simple chatbot unless it performs an enumerated Annex III function. Articles 9-17 (high-risk requirements) assume a provider-deployer relationship with market-placed products; single-operator personal agents collapse all roles into one person. See D3 Sections 4-5.

Where structural gaps exist:

The Act has no legal definition of “agent” or “autonomous agent”—AI systems are defined by their outputs, not by their authority to act on those outputs. Risk classification is anchored to enumerated use cases: an agent that can send thousands of emails, modify codebases, and interact with web services autonomously is treated the same as a spam filter unless it performs recruitment screening, credit scoring, or another listed function. The Act also does not address temporal risk evolution—an agent may start as Minimal Risk and drift into higher-risk activities through learning, with no discrete event triggering re-classification. See D3 Sections 6-7.

4. Cross-Cutting Gaps

Three governance challenges appear across all three frameworks and represent structural gaps in current AI governance for autonomous agents.

4.1 Authority Governance

All three frameworks govern AI outputs (what the system says or recommends). None adequately govern AI authority (what the system is permitted to do). For autonomous agents, the authority model is the primary governance mechanism. Genesis implements this through a four-level autonomy model with action classification and approval gates. No existing framework provides guidance on how to design, validate, or monitor such an authority model.

What is needed: standards or guidance for graduated authority models in autonomous AI systems, including classification of action reversibility, approval gate architecture, and authority regression mechanisms.

4.2 Behavioral Continuity Assurance

All three frameworks assume you can validate an AI system at a point in time. None address the challenge of maintaining behavioral assurance for systems that accumulate state over time. An agent validated today may behave differently next month because its memories, correction history, and learned patterns have changed.

The gap is practical, not theoretical. What would fill it: monitoring approaches for behavioral drift detection in stateful AI systems, including metrics for behavioral consistency, memory integrity verification, and authority exercise pattern analysis.

4.3 External Impact Accountability for Delegated Action

All three frameworks assume a human is accountable for AI-informed decisions. When an agent takes an action autonomously—sending a message, making a purchase, posting content—the accountability chain is less clear. The operator authorized the agent’s general capability but did not approve the specific action. The agent acted within its approved authority level. The recipient of the action may not know an AI system was involved.

No existing framework answers the basic question: accountability models for autonomous AI actions that address: when is the operator accountable versus the system versus the provider, what disclosure obligations attach to autonomous actions, and what redress mechanisms should exist for people affected by autonomous AI actions.

5. Toward an Agentic AI Governance Framework

Based on the gaps identified across all three frameworks, the following elements would be required in a governance framework designed for autonomous AI agents.

5.1 Authority Model Specification

Any governance framework for agents should require documentation and assessment of the system’s authority model: what actions the system can take at each autonomy level, how actions are classified by reversibility and impact, what approval mechanisms gate high-consequence actions, and how authority is earned, constrained, and revoked.

The Genesis model provides one implementation: Bayesian trust accumulation with four levels, three-tier action classification, and an invariant that irreversible actions wait indefinitely for human approval. Other implementations are possible, but the governance requirement should be the same: the authority model must be documented, assessed, and monitorable.

5.2 Continuous Behavioral Assurance

Unlike static AI systems, agents require continuous assurance—ongoing evidence that the system’s behavior remains within expected parameters despite accumulating state changes. This goes beyond traditional monitoring (is the system operational?) to behavioral monitoring (is the system still behaving as intended?).

Minimum requirements would include: behavioral drift detection metrics, memory integrity verification, action classification accuracy tracking, and correction rate trend analysis. The Genesis implementation uses the Bayesian trust model and correction mechanism for behavioral tracking, but a governance standard should define what behavioral assurance means for agents generally.

5.3 External Action Transparency

Agents that take actions affecting people outside the system require transparency mechanisms beyond what Article 50 or ISO 42001 A.8 contemplate. At minimum: disclosure that an AI system is involved in communications, attribution of autonomous actions to the system and its operator, and reporting channels for affected parties.

The challenge is proportionality. A personal agent sending a few emails per week requires different transparency mechanisms than an enterprise agent sending thousands of automated messages daily. A governance framework should scale transparency requirements to the volume and impact of external actions.

5.4 Proactive Operation Governance

Frameworks should address the governance of proactive behavior—actions initiated by the system without a human prompt. This includes: what categories of proactive action are permitted at each authority level, how proactive actions are logged and reviewable, what constraints apply during periods without human oversight, and how the system’s proactive behavior budget is managed.

The Genesis implementation uses ego budgets, cadence controls, and approval gates for proactive operation. These mechanisms have no counterpart in existing governance frameworks.

6. Positioning Against Adjacent Work

This assessment is not the first to observe that governance frameworks need updating for agentic AI. Several recent works address related questions:

AAGATE (Huang, October 2025) proposes an agentic AI governance platform with assessment tooling. The present work differs in methodology: rather than proposing a platform, we applied the existing frameworks to a real system and documented where they break down empirically.

CSA Agentic NIST Profile (March 2026) extends the NIST AI RMF with agentic-specific guidance. This assessment was developed independently and arrives at compatible conclusions from a different direction—assessment of a specific system rather than profile development.

Nannini et al. (April 2026) maps the taxonomy of agentic AI governance requirements. Our assessment provides the empirical control-gap inventory that taxonomic work can be validated against.

ETHOS (Chaffer, December 2024) argues that existing frameworks are inadequate for agentic AI. The present work agrees but goes further: rather than arguing inadequacy in the abstract, we apply the frameworks rigorously and show specifically which gaps are structural (the framework cannot address the concern by design) versus addressable (the framework’s intent covers the concern but its mechanisms need adaptation).

NVIDIA AI-Q (June 2025) proposes custom quality metrics for agentic AI. The present work's MEASURE function analysis (D1, Section 4) identifies similar measurement challenges but from a governance rather than engineering perspective.

The contribution of this assessment series is not the observation that frameworks need updating. It is the specific, empirical, applied analysis of where and how they fall short when confronted with a real deployed autonomous agent. Proposals are useful. Assessments against real systems are rarer and more directly actionable.

References

- Huang, K. et al. (2025). *AAGATE: A NIST AI RMF-Aligned Governance Platform for Agentic AI*. arXiv:2510.25863.
 - Cloud Security Alliance. (2026). *NIST AI Risk Management Framework: Agentic Profile*. CSA Lab Space. <https://labs.cloudsecurityalliance.org/agentic/agentic-nist-ai-rmf-profile-v1/>
 - Nannini, L. et al. (2026). *AI Agents Under EU Law*. arXiv:2604.04604.
 - Chaffer, T.J. et al. (2024). *Decentralized Governance of Autonomous AI Agents*. arXiv:2412.17114.
 - NVIDIA. (2025). *AI-Q Blueprint: Enterprise AI Agent Quality Framework*. <https://build.nvidia.ai>
-

8. Limitations of This Analysis

This analysis is based on a single autonomous agent system (Genesis). The findings may not generalize to all agent architectures. In particular:

- Genesis is single-tenant. Multi-user or multi-agent systems present governance challenges not addressed here (inter-agent coordination, shared authority models, multi-stakeholder accountability).
- Genesis uses a specific authority model (Bayesian trust with approval gates). Agent systems using different authority models (capability-based, role-based, budget-constrained) may face different governance gaps.
- The ISO 42001 analysis is based on secondary source reconstructions of control objectives, not on the normative standard text. Specific control requirements may differ from what secondary sources describe.
- The EU AI Act analysis is based on the Regulation as published, without benefit of implementing acts or harmonized standards that are still in development.

These limitations are documented not as disclaimers but as boundaries for interpretation. Future work applying these frameworks to different agent architectures would strengthen or challenge these findings.